

AAA Digital Platform — Self-Registration Flow

Version 2.0 · 11 May 2026 · Ambitious about Autism

How new users sign up for the training platform. This document is for stakeholders reviewing the registration journey — charity staff, DPO, customer organisations, and auditors.

Major changes since v1.0: The platform now uses a **welcome email + magic-link** flow rather than asking users to pick a password at submission. The **admin-approval gate has been removed** — new users and new organisations are active immediately on submission. OAuth (Google / Microsoft) unknown-email sign-ins now route into a one-question self-registration page rather than failing.

Introduction

The platform has a public sign-up page at </register> where new users create their own account without waiting for an admin to invite them. The form chooses the right path automatically based on a single question at the top: *How are you registering today?*

At a glance

1. **Joining an organisation that's already on the platform** — magic-link email, then instant sign-in.
2. **Setting up a new school or business** — inline password (so the new admin has immediate access), no approval required.
3. **No organisation** — magic-link email, joins the public Toolkit pool.

There's a fourth implicit path: a user who clicks **Sign in with Google** or **Sign in with Microsoft** without an existing account — they're routed to a one-question SSO completion page rather than being rejected.

Path 1 — Joining an existing organisation

The most common path. For someone whose school, college, university, or employer is already using the platform.

Step	What happens
1	User opens <code>/register</code> and selects "I work for or study at an existing organisation" .
2	Types their email and name. No password field.
3	Starts typing the organisation's name — a typeahead lists matching schools / employers. They pick theirs.
4	Picks their role from the list (only roles their org has approved are shown).
5	Clicks Register . Sees a confirmation page: <i>"Check your email — we've sent you a welcome link to set your password."</i>
6	Receives an email titled "Welcome to the AAA Training Platform" with a single button: Set your password and sign in . Token is valid for 24 hours .
7	Clicking the button lands on <code>/welcome?token=...</code> . The user picks a password (10+ chars, mixed case, number, symbol).
8	On submit, the platform mints a NextAuth session cookie server-side. The user is signed in and lands on their dashboard.

Why is this safe to auto-approve?

Each organisation has already told the charity which roles they want to allow (Students only, Practitioners only, etc.). Anyone signing up has to match that allow-list — they can't pick a role their org hasn't authorised. Org admins can deactivate any account at any time from their admin panel. Sign-up attempts are rate-limited (5 / 15 min / IP) to stop abuse. The 24h magic-link TTL means a leaked email + intercepted welcome link is the only theoretical risk, and it's mitigated by the recipient being the only person who can click it.

What if the email is already on the platform?

The form gently tells the user and links them to the sign-in page. No information leaks about whether the email is in an org or in the public pool.

Path 2 — Setting up a new school or business

For a Practitioner, Careers Professional, or Employee whose organisation isn't on the platform yet. They create the organisation and become its first administrator.

Step	What happens
1	User opens <code>/register</code> and selects " I want to register a new school or business ".
2	Picks one of three roles that can register a new org: Practitioner , Careers Professional , or Employee . The choice constrains the organisation types they can create: practitioners and careers professionals can register a school / college / academy / university; employees can register a business (employer).
3	Enters the organisation's details (name, type) and their own name, email, and password (inline, not magic-link).
4	Clicks Register . Both the user account and the new organisation are created with <code>active: true</code> . The user is signed in immediately as the new organisation's <code>ORG_ADMIN</code> .
5	They land on the org admin dashboard and can start adding colleagues, choosing training programmes, configuring SSO etc.

Why no magic link on this path?

The new org admin needs **immediate access** to start configuring their organisation — colleagues, training programmes, announcements. Forcing a magic-link round-trip adds friction at the worst moment. So the password is set inline. Once they're in, the standard MFA enforcement applies (admins must enrol TOTP before doing anything else).

Why no admin approval?

The platform previously required a Charity Admin to approve new organisations before they could be used. That gate was removed in May 2026 — organisations are active immediately. Reasoning: the approval queue was a friction point with no security benefit (anyone determined to fake a school could; the gate just slowed legitimate users). If a fake organisation does appear, a Charity Admin can deactivate it and its users from `/super-admin/organisations` in one click.

Why limit who can do this?

Only Practitioner / Careers Professional / Employee roles can register new organisations. A student or parent shouldn't be able to spin up a fake school — they'd take Path 1 (joining an existing one) or Path

3 (no organisation) instead.

Path 3 — No organisation (public Toolkit pool)

For anyone who wants access to the platform but isn't part of a school, college, or employer — parents, carers, autistic adults, supporters, independent practitioners.

Step	What happens
1	User opens <code>/register</code> and selects "I don't have an organisation" .
2	Picks the option that describes them: <i>I am autistic / I am a parent or carer / I am a supporter / I am a professional working with autistic people</i> .
3	Enters name and email. No password field.
4	Receives a welcome email (same template as Path 1) with a 24h magic link.
5	Clicks the link, lands on <code>/welcome</code> , picks a password, and is signed in.
6	They land in the public Toolkit area, with access tailored to their selected role.

The four options

What describes you?	What you'll be on the platform
I am autistic	Student account
I am the parent / carer / relative of an autistic young person	Parent / Carer account
I am a supporter	Parent / Carer account (general follower)
I am a professional working with autistic people	Practitioner account

Why no "employer" option here?

An employer without an organisation isn't really an employer — they're more of a general supporter. So we've left that option out of this path. Anyone with an actual employer organisation can use Path 2 to register their business; everyone else picks *I am a supporter*.

OAuth completion path (Google / Microsoft)

When OAuth providers are enabled at `/super-admin/settings/sso`, the login page shows **Sign in with Google** and **Sign in with Microsoft** buttons. If a user clicks one and doesn't have a platform account, they're not rejected — they're sent through a short self-registration flow.

Step	What happens
1	User clicks Sign in with Google (or Microsoft) on <code>/login</code> .
2	They complete the provider's consent flow as usual.
3	The platform's <code>signIn</code> callback notices the email isn't in the database. It signs a short-lived (10 min) intent JWT carrying <code>{email, name, provider, providerAccountId}</code> and redirects to <code>/register/sso-complete?token=...</code> .
4	The page asks the same one-question role pick as Path 3 (autistic / parent or carer / supporter / professional).
5	On submit, the platform validates the JWT, creates the user under the public Toolkit pool, links the OAuth <code>Account</code> row, and mints a session cookie. The user lands on their dashboard signed in.

No magic-link round-trip is needed here — the OAuth provider has already verified the email, so the user is trusted to register themselves immediately.

SAML SSO users are still pre-created by the org admin (or auto-provisioned per-org via `OrgSsoConfig.autoProvision`). SAML doesn't route into self-registration.

Special cases

Charity SAML SSO

If a charity SAML SSO is configured (`/super-admin/settings/sso`) with `enforceForCharityUsers = true`, the login page shows only the SAML button — no password field, no OAuth buttons. Charity staff sign in via their corporate IdP. Self-registration is still available at `/register` for non-charity users.

Per-org SAML SSO

If an org has SAML SSO configured for their email domain (e.g. `@city-college.ac.uk`), the login page detects this when the user types their email and shows the SSO button instead of password fields. Sign-in goes via the org's IdP. Self-registration through Path 1 still works for that org if it's enabled — but most enterprise orgs disable self-registration and rely on IdP-side provisioning instead.

Password requirements

Same rules across every path that asks for a password (Path 2 and Path 1's `/welcome` page): at least **10 characters**, with one uppercase letter, one lowercase letter, one number, and one symbol (for example `!`, `@`, `#`, `$`). The form shows live feedback as the user types.

Stopping abuse

- `/api/auth/register` is rate-limited to **5 submissions per 15 minutes per IP**.
- The magic-link `/welcome` route is rate-limited to **5 redemption attempts per 15 minutes per IP**.
- The forgot-password route is rate-limited to **3 emails per 15 minutes per address**.
- Welcome / reset tokens are stored as SHA-256 digests (`lib/reset-token.ts`); if the database leaks, the digests are useless — the token is 32 bytes of CSPRNG output.

Summary

Path	What happens after submit
1 — Existing organisation	Welcome email → magic-link → set password → signed in
2 — New school or business	Inline password set → signed in immediately as new ORG_ADMIN
3 — No organisation	Welcome email → magic-link → set password → signed in (public Toolkit pool)
OAuth (unknown email)	Pick role on <code>/register/sso-complete</code> → signed in immediately (public Toolkit pool)

Implementation references

- Sign-up page: `app/(auth)/register/page.tsx`
- API: `app/api/auth/register/route.ts`
- Welcome page: `app/(auth)/welcome/page.tsx`
- Welcome API: `app/api/auth/welcome/route.ts`
- OAuth completion page: `app/(auth)/register/sso-complete/page.tsx`
- OAuth completion API: `app/api/auth/register/sso-complete/route.ts`
- Welcome email template: `lib/email-templates/welcome.ts`
- Token hashing: `lib/reset-token.ts`
- Auth wiring (provider registration + `signIn` callback): `lib/auth.ts`
- Rate-limit factory: `lib/rate-limit.ts`

Prepared for: Ambitious about Autism Document: AAA Self-Registration Flow — Handover Status: For review